

Chapter 1

Computer Forensics- deals with the process of finding evidence related to a digital crime

Cybercrime refers to “any illegal act that involves a computer, its systems, or its applications.”

Internal Attacks:

Insider attacks, considered as a primary threat, refer to attacks by disgruntled individuals working in the same firm or household as the victim. Examples of internal attacks include espionage, theft of intellectual property, manipulation of records, and Trojan horse attack.

External attacks:

External attacks originate from outside of an organization or can be remote in nature. Such attacks occur when there are inadequate information security policies and procedures.

Rules of Forensics Investigation

A forensic examiner must keep in mind certain rules to follow during a computer forensic examination, as well as to handle and analyze the evidence. This will safeguard the **integrity** of the evidence and render it **acceptable** in a court of law. The forensic examiner must **make duplicate copies** of the original evidence and start by **examining only the duplicates**. The duplicate copies must **be accurate** replications of the originals, and the forensic examiner must also **authenticate the duplicate copies** to avoid questions about the **integrity** of the evidence. The computer forensic examiner **must not continue** with the investigation if the examination is **going to be beyond his or her knowledge level** or skill level.

Forensic investigators should memorize the rules listed below.

- Limit access and examination of the original evidence
- Record changes made to the evidence files
- Create a chain of custody document
- Set standards for investigating the evidence
- Comply with the standards
- Hire professionals for analysis of evidence
- Evidence should be strictly related to the incident
- The evidence should comply with the jurisdiction standards
- Document the procedures applied on the evidence
- Securely store the evidence
- Use recognized tools for analysis

Enterprise Theory of Investigation (ETI) -ETI is a methodology for investigating criminal activity. It adopts a holistic approach toward any criminal activity as a criminal operation rather than as a single criminal act.

Understanding Digital Evidence

Digital evidence includes all such information that is either stored or transmitted in digital form and has probative value. Investigators should take utmost care while gathering digital evidence as it is fragile in nature. According to **Locard's Exchange Principle**, “anyone or anything, entering a crime scene **takes something** of the scene, and **leaves something** of themselves behind.”

Digital Forensics Challenge

Forensic investigators face many challenges during forensics investigation of a digital crime, such as extracting, preserving, and analyzing the digital evidence. For example, system data that an **intruder can easily change** or destroy **should have priority** while assembling the evidence.

Volatile Data: Volatile data refers to the temporary information on a digital device that requires a constant power supply and is deleted if the power supply is interrupted. Important volatile data includes **system time, logged-on user(s), open files, network information, process information, process-to-port mapping, process memory, clipboard contents, service/driver information, command history, etc.**

Non-volatile Data: Non-volatile data refers to the permanent data stored on secondary storage devices, such as hard disks and memory cards. Information stored in non-volatile form includes **hidden files, slack space, swap file, index.dat files, unallocated clusters, unused partitions, registry settings, and event logs.**

Characteristics of Digital Evidence

Admissible Evidence relevant to the case, act in support of the client presenting it, and be well communicated and non-prejudiced.

Authentic investigators must provide supporting documents regarding the authenticity, accuracy, and integrity of the evidence with details such as source and its relevance to the case. If necessary, they must also furnish details such as author of the evidence or path of transmission.

Complete must either prove or disprove the consensual fact in the litigation

Reliable extract and handle the evidence while maintaining a record of the tasks performed during the process to prove that the evidence is dependable. Forensic investigation is conducted only on the copies of evidence.

Believable present evidence in a clear manner to the jury and obtain expert opinions where necessary

Best Evidence Rule

The best evidence rule is to **prevent any alteration** of digital evidence, either intentionally or unintentionally.

Duplicate will also suffice as evidence under the following conditions:

- Original evidence is destroyed due to fire and flood.
- Original evidence is destroyed in the normal course of business.
- Original evidence is in possession of a third party.

Types of approaches to manage cybercrime investigations

Civil cases involve disputes between two parties, which may include an individual versus a company, an individual versus another individual, or a company versus another. They relate to **violation of contracts and lawsuits, where a guilty verdict generally results in monetary damages to plaintiff.**

Criminal Cases criminal cases involve actions that are against the norms of society. **DID YOU KNOW WHAT YOU DID? IF SO, IT IS CRIMINAL.**

- Investigators must follow a set of standard forensic processes accepted by law in the respective jurisdiction.
- Investigators, under court's warrant, have the authority to seize the computing devices.
- A formal investigation report is required.
- The law enforcement agencies are responsible for collecting and analyzing evidence.
- Punishments are harsh and include fine, jail sentence or both.
- Standard of proof needs to be very high.
- Difficult to capture certain evidence, e.g., GPS device evidence

Administrative Investigation refers to an **internal investigation by an organization** to discover if its employees, clients and partners are abiding by the rules or policies. **Violation of company policies.**

- Involves an agency or government performing inquiries to identify facts with reference to its own management and performance
- **Non-criminal in nature and related to misconduct** or activities of an employee that includes but are not limited to:
 - Violation of organization's policies, rules, or protocols. Resource misuse or damage or theft
 - Threatening or violent behavior. Sexual Exploitation, harassment and abuse
 - Improper promotion or pay raise, corruption and bribery

Scientific Working Group on Digital Evidence (SWGDE)

Principle 1 To ensure that digital evidence is collected, preserved, examined, or transferred in a manner that safeguards the accuracy and reliability of the evidence, law enforcement and forensic organizations must establish and maintain an effective system for quality control.

Standards and Criteria

- 1.1** All agencies that seize and/or examine digital evidence **must maintain an appropriate SOP** document.

- 1.2 Agency mgmt. must review SOPs on an annual basis to ensure their continued suitability and effectiveness.
- 1.3 SOPs must be generally accepted or supported by data gathered and recorded in a scientific manner.
- 1.4 The agency must maintain written copies of the appropriate technical procedures.
- 1.5 The agency must use hw and sw that is appropriate and effective for the seizure/examination procedure.
- 1.6 All activities related to the seizure, storage, examination, or transfer of digital evidence must be recorded in writing and be available for review and testimony.

Forensic Readiness refers to an organization's ability to make optimal use of digital evidence in a limited period and with minimal investigation costs. It includes technical and nontechnical actions that maximize an organization's competence to use digital evidence.

A forensic investigator performs the following tasks:

- Evaluates the damages of a security breach
- Identifies and recovers data required for investigation
- Extracts the evidence in a forensically sound manner
- Ensures proper handling of the evidence
- Acts as a guide to the investigation team
- Creates reports and documents about the investigation required to present in a court of law
- Reconstructs the damaged storage devices and uncovers the information hidden on the computer
- Updates the organization about various methods of attack and data recovery techniques, and maintains a record of them (following a variant of methods to document) regularly
- Addresses the issue in a court of law and attempts to win the case by testifying in court
- **Fourth Amendment** states that government agents may **not search or seize** areas or things in which a person has a reasonable expectation of privacy, without a search warrant. **Note:** Private intrusions not acting in the color of governmental authority do not come under the Fourth Amendment.

CHAPTER 1 SUMMARY

- Computer forensics refers to a set of procedures and techniques to identify, gather, preserve, extract, interpret, document and present evidence from computing equipment that is acceptable in court
- Cybercrime is defined as any illegal act involving a computing device, network, its systems, or its applications. Categorized into two types based on the line of attack: internal attacks and external attacks
- Computer crimes pose new challenges for investigators due to their speed, anonymity, volatile nature of evidence, global origin and difference in laws, and limited legal understanding
- Approaches to manage cybercrime investigation include: civil, criminal, and administrative
- Digital evidence is "any information of probative value that is either stored or transmitted in a digital form". It is of two types: volatile and non-volatile
- Forensic readiness refers to an organization's ability to make optimal use of digital evidence in a limited period of time and with minimal investigation costs
- Organizations often include computer forensics as part of incident response plan so as to track and prosecute perpetrators of an incident

Chapter 2

The **computer forensics investigation process** includes a methodological approach for preparing for the investigation, collecting and analyzing evidence, and managing the case from reporting to the conclusion.

Phases Involved in the Computer Forensics Investigation Process

Pre-investigation Phase: all the tasks performed prior to the commencement of the actual investigation

- setting up a **computer forensics lab**(CFL), toolkit, and workstation
- the investigation team and getting approval from the relevant authority
- planning the process, defining mission goals, and **securing the case perimeter and devices involved.**
- **Investigation Phase:** Main phase of the computer forensics investigation performed by professionals
- acquisition, preservation, and analysis of the data to identify the source of crime and the culprit.

- implementing the technical knowledge to find evidence, examine, document, and preserve the findings.
- **Post-investigation Phase:** Reporting and documentation of all the actions undertaken and the findings during the course of an investigation.
- Ensure that the target audience can easily understand the report
- ensure report provides adequate and acceptable evidence.
- report should comply with all local laws and standards
- it should be legally sound and acceptable in the court of law.
- **Setting up a CFL:**
- Planning and budgeting
- Location and structural concerns. Work area considerations (50-63 sqft per station) no windows
- HR Considerations (certifications and experience)
- Physical security recommendations. Have the lab forensically licensed
 - ASCLD/Lab Accreditation
 - ISO/IEC 17025

TEMPEST is an unclassified short name referring to investigations and studies of compromising emanations. **Compromising emanations are unintentional intelligence-bearing signals** that if intercepted and analyzed will disclose classified information when it is transmitted, received, handled, or otherwise processed by any information processing equipment."

A **search warrant** is a written order issued by a judge that directs a law enforcement officer to search for a particular piece of evidence at a particular location

Forensic Hardware Tools

- **FRED** systems are optimized for stationary laboratory acquisition and analysis. FRED will acquire data directly from IDE/EIDE/ATA/SATA/ATAPI/SAS/Firewire/USB hard drives and storage devices and save forensic images to Blu-Ray, DVD, CD, or hard drives.
- **Paraben's StrongHold** Faraday Bags block out wireless signals to protect evidence.
- **PC-3000 Data Extractor** diagnoses and fixes file system issues, so that the client's data can be obtained.
- **Paraben's Chat Stick** is a thumb drive device that will search the entire computer and scan it for chat logs
- **RAPID IMAGE 7020 X2** designed to copy one "Master" hard drive to up to 19 "Target" hard drives
- **RoadMASter-3 X2** is a forensic ruggedized portable lab for hdd data acquisition and analysis.
- **Image MASterTM Wipe PRO** is a hard Drive Sanitization Station.
- **PC-3000 Flash** is a hardware and software suite for recovering flash- based storage
- **ZX-Tower** provides secure sanitization of hard disk
- **WriteProtect-DESKTOP** provides secure, read-only write-blocking of suspect hard drives.
- **Data Recovery Stick** can recover deleted files.
- **Tableau T8-R2 Forensic USB Bridge** offers secure, hw-based write blocking of USB storage devices.
- **Forensic Software Tools**
- **Cain & Abel** pw recovery for MS OS. Uses sniffing, dictionary, brute-force, and cryptanalysis attacks. Also record VoIP, decode scrambled passwords, recover wireless keys, reveal password boxes, uncover cached passwords and analyze routing protocols.
- **Recuva** recover lost pictures, music, docs, video, email, or other file type from all types of media
- **Capsa** sniffer with support for over 300 network protocols
- **R-Drive Image** utility that provides creation of disk image files for backup or duplication purposes.
- **FileMerlin** converts word processing, xls, ppt and database files between a wide range of file formats.
- **AccessData FTK** court-cited digital investigations platform that provides processing and indexing up front, so filtering and searching is fast. FTK can be setup for distributed processing and incorporate web-based case management and collaborative analysis.

- **Guidance Software's EnCase** Rapidly acquire data from variety of devices and unearth potential evidence with disk-level forensic analysis. Produce comprehensive reports on your findings and maintain the integrity of your evidence in a format the courts have come to trust
- **Nuix Corporate Investigation Suite** used to collect, process, analyze, review, and report evidence.
- **PALADIN** is a modified "live" Linux distribution based on the PALADIN Toolbox.
- **The Sleuth Kit** cmd line tools and a C library to analyze disk images and recover files from them.
- **Autopsy** digital forensics platform and gui to The Sleuth Kit® and other digital forensics tools.
- **Oxygen Forensic Kit** is a ready-to-use and customizable mobile forensic solution for field and in-lab usage. Allows extraction of data from the device but also creates reports and analyzes data in the field.
- **L0phtCrack** is a password auditing and recovery software.
- **Ophcrack** is a free GUI driven Windows password cracker based on rainbow tables
- **NIST has launched the Computer Forensic Tool Testing Project (CFTT), which establishes a "methodology for testing computer forensic software tools by development of general tool specifications, test procedures, test criteria, test sets, and test hardware."**

Forensic Investigation Team

- **Attorney:** legal advice about the investigation, and legal issues involved in the forensics investigation process.
- **Photographer:** Photographs the crime scene and all evidence. Should have an authentic certification.
- **Incident Responder:** Responsible for the measures taken when an incident occurs, securing the incident area and collecting the evidence that is present at the crime scene. **He or she should disconnect the system** from other systems to stop the spread of an incident
- **Decision Maker:** The person responsible for authorization of a policy or procedure during the investigative process. Based on the incident type, **makes decision about the policies and procedures** to handle the incident.
- **Incident Analyzer:** Analyzes the incidents based on their occurrence. He or she examines the incident with regard to its type, how it affects the systems, different threats and vulns associated with it
- **Evidence Examiner/Investigator:** Examines the evidence acquired and sorts the useful evidence.
- **Evidence Documenter:** gathers info and documents it from incident occurrence to the end of the investigation.
- **Evidence Manager:** has all the information about the evidence: name, evidence type, time, source of evidence, etc. manages and maintains a record of the evidence such that it is admissible in the court of law.
- **Expert Witness:** Offers a formal opinion as a testimony in a court of law.

Forensic Laws

- **18 USC §1029** - Fraud and related activity in connection with access devices
- **18 USC §1030** - Fraud and related activity in connection with computers
- **18 USC §1361-2** - Prohibits malicious mischief
- **18 USC §2252A** -law about child pornography
- **18 USC §2252B** -misleading domains on Internet
- **18 USC §2702** - voluntary disclosure of contents to government and non-government entities
- **42 USC §2000AA** -Privacy Protection Act, special steps to take during seizure that don't prevent freedom of expression
- **Rule 402** - General Admissibility of Relevant Evidence
- **Rule 502** - Attorney-Client privilege and work product; Limitations on waiver
- **Rule 608** - Evidence of character and conduct of witness
- **Rule 609** - Impeachment by evidence of a criminal conviction
- **Rule 614** - Calling and interrogation of witnesses by court
- **Rule 701** - Opinion testimony by lay witnesses
- **Rule 705** - Disclosure of facts or data underlying expert opinion
- **Rule 801** - hearsay
- **Rule 901** - Authenticating or Identifying Evidence

- **Rule 1002** - Requirement of original
- **Rule 1003** - Admissibility of duplicates
- **Rule 1004** - Admissibility of other evidence of Content

Checklist to Prepare for a Computer Forensics Investigation

- 1 Do not turn the computer off or on, run any programs, or attempt to access data on the computer.
- 2 Secure any relevant media including hard drives, cell phones, DVDs, USB drives, etc subject may have used
- 3 Suspend document destruction and recycling that may pertain to relevant media or users at the time of issue
- 4 Perform a preliminary assessment of the crime scene and identify the type of data you are seeking, the information you are looking for, and the urgency level of the examination
- 5 Once the machine is secured, obtain info about the machine, the peripherals, and network where connected
- 6 If possible, obtain passwords to access encrypted or password-protected files
- 7 Compile a list of names, e-mails, and other info of those with whom the subject might have communicated
- 8 If the computer is accessed before the forensic expert is able to secure a mirror image, note the user(s) who accessed it, what files accessed, and when access occurred. If possible, find out why the pc was accessed
- 9 Maintain a chain of custody for each piece of original media, indicating where the media has been, whose possession it has been in, and the reason for that possession.
- 10 Create a list of key words or phrases to use when searching for relevant data

Best Practices

- Get authorization to conduct the investigation, from an authorized **decision maker**
- **Document all the events** and decisions at the time of the incident and incident response
- Depending on the scope of the incident and presence of any national security issues or life safety issues, the **first priority is to protect the organization from further harm**
- **The following are the Computer Forensics Investigation Methodology:**
 - First Response
 - Search and Seizure
 - Collect the Evidence
 - Secure the Evidence
 - Data Acquisition
 - Data Analysis
 - Evidence Assessment
 - Documentation and Reporting
 - Testify as an Expert Witness

Documentation of the electronic crime scene is a **continuous process** during the investigation, making a permanent record of the scene. It includes photographing and sketching of the scene.

- If the evidence gathered by the CFP suggests that the suspect has committed a crime, he or she will produce that evidence in court. If the evidence suggests that the suspect has breached company policy, the CFP will hand over the evidence at the corporate enquiry.
- If the **suspect is present** at the time of the search and seizure, the **incident manager or the laboratory manager** may consider asking some questions. However, they must comply with the relevant human resources or legislative guidelines with regard to their jurisdiction

Warrants

Electronic storage device warrant allows the first responder to search and seize the victim's computer components such as HW/SW, Storage devices, Documentation

Service Provider search warrant allows first responders or investigators to consult the service provider and obtain the available **victim's computer information and** Service records, Billing records, Subscriber information

“When destruction of evidence is imminent, a warrantless seizure of that evidence is justified if there is probable cause to believe that the item seized constitutes evidence of criminal activity.” United States v. David, 756 F. Supp. 1385, 1392 (D. Nev. 1991). Agents **may search** a place or object without a warrant or probable cause, if a person with authority has consented. Schneckloth v. Bustamonte, 412 U.S. 218, 219 (1973).

Dealing with Powered Off Computers

At this point of the investigation, do not change the state of any electronic devices or equipment:

- If it is switched OFF, leave it OFF
- If a monitor is switched OFF and the display is blank:
- Turn the monitor ON, move the mouse slightly, observe the changes from a blank screen to another screen, and note the changes and photograph the screen.
- If a monitor is switched ON and the display is blank
- Move the mouse slightly. If the screen does not change, do not perform any other keystroke.
- Photograph the screen.

Dealing with Networked Computer If the victim’s computer has an Internet connection, the first responder must follow the following procedure in order to protect the evidence:

- Unplug the network cable from the router and modem internet can make it vulnerable to further attack
- Don’t use the pc for evidence search because it may alter or change the integrity of the existing evidence
- Unplug all the cords and devices connected to the computer and label them for later identification
- Unplug the main power cord from the wall socket
- Pack the collected electronic evidence properly and place it in a static-free bag
- Keep the collected evidence away from magnets, high temperature, radio transmitters, and other elements that may damage the integrity of the evidence
- Document all the steps that involved in searching and seizing the victim’s computer for later investigation

Preserving Electronic Evidence

- Document the actions and changes observed on the monitor, system, printer, or other electronic devices
- Verify that the monitor is ON, OFF, or in sleep mode
- Remove the power cable, depending on the power state of the computer, i.e., ON, OFF, or in sleep mode
- Do not turn ON the computer if it is in the OFF state
- Take a photo of the monitor screen if the computer is in the ON state
- Check the connections of the telephone modem, cable, ISDN, and DSL
- Remove the power plug from the router or modem
- Remove any portable disks that are available at the scene to safeguard potential evidence
- Keep the tape on drive slots and the power connector
- Photograph the connections between the computer system and the related cables, and label them
- Label every connector and cable connected to the peripheral devices

Chain of Custody legal document that demonstrates the progression of evidence as it travels from the original evidence location to the forensic laboratory. It is a roadmap that shows how investigators collected, analyzed, and preserved the evidence. It ensures accurate auditing of the original data evidence, imaging of the source media, tracking of the logs, and so on. The chain of custody shows the technology used and the methodology adopted in the forensic phases as well as the persons involved in it. The chain of custody administers the collection, handling, storage, testing, and disposition of evidence. It helps to ensure protection of evidence against tampering or substitution of evidence. Chain of custody documentation should list all the people involved in the collection and preservation of evidence and their actions, with a stamp for each activity.

Exhibit numbering the process of tagging evidence with sequential number, which includes case and evidence details. This will allow the investigator to easily identify the evidence and know its details.

The investigators should mark all the evidence in a pre-agreed format, such as: **aaa/ddmmyy/nnnn/zz**.

- **aaa** are the initials of the forensic analyst or law enforcement officer seizing the equipment.
- **dd/mm/yy** is the date of seizure.
- **nnnn** is the sequential number of the exhibits seized by aaa, starting with 001 and going to nnnn.
- **zz** is the sequence number for parts of the same exhibit (e.g., 'A' could be the CPU, 'B' the monitor, 'C' the keyboard, etc.)

Image Integrity Tools:

- **HashCalc**-created MD5 hash for files, text and hex strings; 13 different algorithms
- **MDF Calculator**-view MD5 hash to compare to provided hash value
- **HashMyFiles**-calculate MD5 hash on one or more files. Can also display MD5 hashes of files or folders
- **Recover Lost or Deleted Data**
- **Recover My Files**-recover deleted files emptied from recycle bin, accidental format, hard disk crash, etc.
- **Recuva**-recover all types of lost files from disk or removable media
- **Advanced Disk Recovery**-quick or deep scan for lost or deleted files
- **UndeletePlus**-same as above
- **Data Analysis Tools**
- **FTK Imager**- data preview and imaging tool that enables analysis of files and folders on local hard drives, CDs/DVDs, network drives, and examination of the content of forensic images or memory dumps. FTK Imager can also create MD5 or SHA1 hashes of files, review and recover files deleted from the Recycle Bin, export files and folders from forensic images to disk and mount a forensic image to view its contents in Windows Explorer.
- **EnCase Forensic**- popular multi-purpose forensic platform that includes many useful tools to support several areas of the digital forensic process. It also generates an evidence report. EnCase Forensic can help investigators acquire large amounts of evidence, as fast as possible from laptops and desktop computers to mobile devices. EnCase Forensic directly acquires the data and integrates the results into the cases.
- **The Sleuth Kit (TSK)** -library and collection of command line tools that allows investigating disk images. The core functionality of TSK allows analyzing volume and filing system data. The plug-in framework also allows incorporating additional modules to analyze file contents and build automated systems. The library can be incorporated into larger digital forensics tools and the command line tools can be directly used to find evidence.

Tools to obtain information from different common social media websites:

- Netvizz, twecoll, divud, Digitalfootprints, Netlytic, X1 Social Discovery, Facebook Forensic Software
- H&A forensics, Geo360, Navigator by LifeRaft Social, Emotive, etc.

Chapter 2 Summary

- 3 phases in Computer Forensics Investigation Process, Pre-investigation, Investigation and Post-Investigation
- A CFL is a location designated for conducting a computer-based investigation on the collected evidence
- Search warrant is an order from a judge that directs LE to search for a particular piece of evidence at a particular location
- Make a duplicate of the collected data so as to preserve the original
- To preserve the integrity of the physical evidence, all evidence collected should be handled carefully
- All digital evidence must be stored in a container, which must be secured to prevent unauthorized access
- Documentation of the electronic crime scene is a continuous process during the investigation that creates a permanent record of the scene
- Final report should include what the investigator did during the investigation, and what he or she found

Chapter 3

Hard Disks and Filesystems

- **Platters** circular metal disks mounted into a drive enclosure

- **Tracks** are concentric rings on the platters that store data; each track has smaller partitions called **disk blocks or sectors**. Track numbering starts at 0 and goes to 1023.
- **Sectors** are the **smallest physical storage** units located on a hard disk platter and are 512bytes long. New format sectors are 8 512B sectors to make one 4096B or 4KB sector; which is more efficient
- **Clusters** are the **smallest accessible/logical storage units** on the hard disk. Clusters form by combining sectors in order to ease the process of handling files. Also called allocation units, the clusters are sets of tracks and sectors ranging from 2 to 32, or more, depending on the formatting scheme
- **Slack space** is the wasted area of the disk cluster lying between end of the file and end of the cluster when the file system allocates a full cluster to a file, which is smaller than the cluster size.
- **Bad sectors** refer to the portions of a disk that are unusable due to some flaws in them and do not support the read or write operations. The data stored in bad sectors is not completely accessible. Bad sectors might be due to configuration problems or any physical disturbances to the disk.
- **Master Boot Record (MBR)** refers to a hard disk's first sector or **sector zero** that specifies the location of an operating system for the system to load into the main storage. Also called as, partition sector or master partition table contains a table, which locates partitioned disk data. **HOW BIG IS IT? 512BYTES**
- A **sparse file** is a type of computer file that attempts to use file system space more efficiently when blocks allocated to the file are mostly empty.
- **Cylinders, Heads, and Sectors (CHS)** determine the sector addressing for individual sectors on a disk
- **Logical Block Addressing (LBA)** addresses data by allotting a sequential number to each sector
- **BIOS Parameter Block (BPB)** data at sector 1 in the volume boot record and explains the layout
- **Master Boot Code** loads into BIOS and initiates system boot process

Master Boot Record (MBR)

- 512bytes long
- contains four 16-byte master partition records
- MBR starts @ sector 0
- volume boot sector is present in cylinder 0, head 0, and sector 1 of the default drive
- MBR signature or end of sector is always **0x55AA**

Back up the MBR:

```
dd if=/dev/xxx of=mbr.backup bs=512 count=1
```

Restore the MBR:

```
dd if=mbr.backup of=/dev/xxx bs=512 count=1
```

Globally Unique Identifier (GUID)

- 128-bit unique number generated by windows used to identify COM DLLs, primary key values, browser sessions, and usernames
- contains four 16-byte master partition records

GUID Partition Table (GPT)

- allows for disks larger than 2T and allows users to have 128 partitions on windows
- partition and boot data is more secure than MBR
- uses CRC to ensure data integrity and CRC32 checksum for header and partition table

Windows Boot Process

1. System switches ON, CPU sends a Power Good signal to mboard and checks for computer's BIOS firmware.
2. BIOS starts a POST and load all the firmware settings from nonvolatile memory on the mboard.
3. If POST is successful, add-on adapters perform a self-test for integration with the system.
4. The pre-boot process will complete with POST, detecting a valid system boot disk.
5. After POST, the computer's firmware scans boot disk and loads the master boot record (MBR), which search for basic boot information in Boot Configuration Data (BCD).

6. MBR triggers Bootmgr.exe, which locates Windows loader (Winload.exe) on the Windows boot partition and triggers Winload.exe.
7. Windows loader loads the OS kernel ntoskrnl.exe.
8. Once the Kernel starts running, the Windows loader loads HAL.DLL, boot-class device drivers marked as BOOT_START and the SYSTEM registry hive into the memory.
9. Kernel passes the control of boot process to the Session Manager Process (SMSS.exe), which loads all other registry hives and drivers required to configure Win32 subsystem run environment.
10. Session Manager Process triggers Winlogon.exe, which presents the user logon screen for user authorization.
11. Session Manager Process Initiates Service control manager, which starts all the services, rest of the non-essential device drivers, the security subsystem LSASS.EXE and Group policy scripts.
12. Once user logs in, Windows creates a session for the user.
13. Service control manager starts the Explorer.exe and initiates the Desktop Window Manager (DMW) process, which set the desktop for the user.

Deleted and Overwritten GUID Partitions

Case 1: In hard disks, the conversion or repartition of the MBR disk to GPT will generally overwrite the sector zero with a protective MBR, which will delete all the information about the old partition table. The investigators should follow the standard forensics methods of searching the filesystems to recover data about the previous MBR partitioned volumes.

Case 2: When conversion or repartition of the GPT to MBR disk takes place, then the GPT header and tables may remain intact based on the tool used. Investigators can easily recover or analyze data of such disk partitions. Implementation of general partition deletion tools for deletion of partition on the GPT disk will delete the protective MBR only, which investigators can easily recreate by simply reconstructing the disk.

Mac Boot Process

1. Activation of BootROM, which initializes system hardware and selects an operating system to run.
2. BootROM performs POST to test some hardware interfaces required for startup.
3. On PowerPC-based Macintosh computers, Open Firmware initializes the rest of the hardware interfaces.
4. On Intel-based Macintosh computers, EFI initializes the rest of the hardware interfaces.
5. After initializing the hardware interfaces, the system selects the operating system.
6. If the system contains multiple operating systems, it allows the user to choose the particular operating system by holding down the Option key.
7. Once the BootROM operation is finished, the control passes to the BootX (PowerPC) or boot.efi (Intel) boot loader, which is located in the /System/Library/CoreServices directory.
8. The boot loader loads a pre-linked version of the kernel, which is located at /System/Library/Caches/com.apple.kernelcaches .
9. Once the essential drivers are loaded, the boot loader starts initialization of the kernel, Mach and BSD data structures, as well as the I/O kit.
10. The I/O kit uses the device tree to link the loaded drivers to the kernel.
11. The launchd, which has replaced the mach_init process, runs startup items and prepares the system

Linux Boot Process

1. **BIOS stage**
 - a. It initializes the system hardware.
 - b. The BIOS retrieves the information, stored in the CMOS chip and then performs a POST test.
 - c. BIOS starts searching for the drive or disk which contains the operating system in a standard sequence.
2. **Bootloader Stage**
 - a. Load the Linux kernel and optional initial RAM disk.
 - b. Load pre-cursor software in a virtual file system called the initrd image or initial RAMdisk
 - c. System prepares to deploy the actual root file system.
 - d. System detects the device that contains the file system and loads the necessary chapters.

- e. Lastly, load the kernel into the memory.

3. Kernel Stage

- a. Virtual root file system executes the Linuxrc program. This generates the real file system for the kernel and later removes the initrd image.
- b. Kernel searches for new hardware and loads any suitable device drivers found.
- c. mounts the actual root file system and then performs the init process.
- d. init reads the file “/etc/inittab” and uses this file to load the rest of the system daemons. This prepares the system and the user can log in and start using it.
- e. Bootloaders for Linux are LILO (Linux Loader) and GRUB (Grand Unified Bootloader). These bootloaders allow the user to select which OS kernel to load during boot time.

Types of File Systems

- Disk File System-used to store data on disks or other media
- Network File System-used to access files on other computers or a NAS. NFS, CIFS, or GFS
- Database File System-used to store and manage files stored on a computer or server
- Flash File System-stores files or data in flash memory devices
- Tape File System-stores data/files on tape in self-describing form; very slow
- Shared Disk File System-external disk array or SAN accessed by servers or workstations
- Special Purpose File System-organizes files during run time and uses them for tasks. UNIX uses this.

Windows File Systems

- FAT (file allocation table-16)
 - Designed for small disks with simple folder structures. Stores all files at beginning of volume
 - Creates two copies of allocation table for damage recovery
 - Flash, digital cameras, and other portable devices
- FAT32
 - Utilizes space 10-15% more effectively due to use of smaller clusters
 - Very robust and has lesser failure rate than FAT16 devices
 - No restriction on number of root folder entries
- New Technology File System (NTFS)
 - High-performance, self-repairing with advanced features like file-level security, compression, and auditing
 - Supports larger and more powerful volume storage solutions like RAID
 - Can encrypt/decrypt data, uses 16-bit Unicode for multi-language support, maintains fault tolerance via a backup log file
 - Introduces concept of metadata and master file tables
 - Supports files up to 16GB
 - Uses MFT (relational database) for file attributes like size, time, date, permissions, and contents

Linux File System

- User Space: The protected memory area where the user processes run and this area contains the available memory.
- Kernel Space: The memory space where the system supplies all kernel services through kernel processes. The users can access this space through the system call only. A user process turns into kernel process only when it executes a system call.
- The GNU C Library (glibc) sits between the User Space and Kernel Space and provides the system call interface that connects the kernel to the user-space applications.

Filesystem Hierarchy Standard (FHS)

Directory	Description
/bin	Essential command binaries. Ex: cat, ls, cp.
/boot	Static files of the boot loader. Ex: Kernels, Initrd
/dev	Essential device files. Ex: /dev/null
/etc	Host-specific system configuration files
/home	Users' home directories, holding saved files, personal settings, etc.
/lib	Essential libraries for the binaries in /bin/ and /sbin/
/media	Mount points for removable media
/mnt	Temporarily mounted filesystems
/opt	Add-on application software packages
/root	Home directory for the root user
/proc	Virtual file system providing process and kernel information as files
/run	Information about running processes. Ex: running daemons, currently logged-in users
/sbin	Contains the binary files required for working
/srv	Site-specific data for services provided by the system
/tmp	Temporary files
/usr	Secondary hierarchy for read-only user data
/var	Variable data. Ex: logs, spool files, etc.

Extended File System (EXT)

- First filesystem developed for Linux in 1992
- Metadata structure similar to UFS

Second Extended File System (EXT2)

- Most successful file system for linux and basis for all linux distros
- Data is stored in blocks of the same length during creation

Third Extended File System (Ext3)

- Journaling file system used in GNU/Linux OS; enhanced version of EXT2
- Main advantage is journaling and improves reliability/integrity and speed
- Can convert from ext2 to ext3 or vice versa

Fourth Extended File System (EXT4)

- Better scale and reliability than EXT3
- Replaces block mapping scheme of EXT2/3 to increase performance and reduce fragmentation

Hierarchical File System (HFS) Developed to replace MFS or Mac File System

HFS Plus (HFS+) successor of HFS and is a primary file system in Macintosh.

UFS (UNIX File System) used by UNIX and UNIX-like OS

ZFS-used by Sun. High storage capacity, data protection, compression, volume management, integrity checks, deduplication, encryption, and auto repair.

ISO 9660 a standard that defines uses for file systems of CD-ROM and DVD media.

ISO 13490

- POSIX attributes and multi-byte characters
- efficient format that allows incremental recording and also permit the ISO 9660 format and the ISO/IEC 13490 format to exist on the same media
- specifies using multicasting properly.

CD File System (CDFS)

- file system for the Linux operating system
- transfers all tracks and boot images on a CD, as normal files. These files can then be mounted (for example, for ISO and boot images), copied, and played. Goal was to unlock information in old ISO images.

Universal Disk Format File System (UDF)

- defined by Optical Storage Technology Association (OSTA) to replace the ISO9660 file system on optical media and also FAT on removable media.
- open source file system based on ISO/IEC 13346 and ECMA- 167 standards that defines how a variety of optical media store and interchange the data.

RAID Level 0: Disk Striping

It is the simplest RAID level, which does not involve any redundancy and fragments the file into user-defined stripe size of the array. Then it sends these **stripes** to every disk in the array. As **RAID 0** does not have redundancy, it allows this RAID level to offer the **best overall performance** characteristics of the single RAID levels. Requires at **least two** drives

RAID 1 generally executes **mirroring** as it duplicates or copies the drive data on to two different drives using a hardware RAID controller or a software. If one of the drives fail, the other will function as a single drive until a user replaces the failed drive with a new one. Requires minimum of **2 drives**.

RAID 2 is the only level among all the RAID levels that does not implement even one of the standard techniques of parity, mirroring or striping. It uses a technique similar to striping with parity. It includes splitting of data at the bit level and distributing it to numerous data disks and redundancy disks.

RAID 3 uses byte-level striping with a dedicated parity disk, which stores checksums. It also supports a special processor for parity codes calculation. This RAID **cannot cater multiple data requests simultaneously**. If a failure occurs, it enables data recovery by an applicable calculation of the parity bytes, and the remaining bytes which relate with them.

RAID 5

Uses byte level data striping across multiple drives, and distributes the parity information among all member drives. Data writing process is slow. It **requires a minimum of three drives** to set up. The RAID stripes and distributes the error detection and correction code or Data and parity code across three or more drives.

RAID 10, also known as RAID 1+0, is a combination of RAID 0 (Striping Volume Data) and RAID 1 (Disk Mirroring) to protect data. It **requires at least four drives** to implement. It has same fault tolerance as RAID level 1 and the same overheads as mirroring alone. It allows mirroring of disks in pairs for redundancy and improved performance, and then stripes data across multiple disks for maximum performance. The user retrieves data from the RAID if one disk in each mirrored pair is working; however, if two disks in the same mirrored pair fail, the data is not available.

American Standard Code for Information Interchange (ASCII)

- 128 specified characters coded into 7-bit integers.
- Source code of a program, batch files, macros, scripts, HTML and XML documents
- 0 to 9, a-z, A-Z, Basic punctuation symbols, Control codes that originated with teletype machines
- ASCII table has 3 divisions namely, non-printable (system codes between 0 and 31), lower ASCII (codes between 32 and 127), and higher ASCII (codes between 128 and 255). The graphics files and documents use non-ASCII characters made in word processors, spreadsheet or database programs and sent as email file attachments.

Unicode computing standard developed with the Universal Coded Character Set (UCS) standard for encoding, representation, and management of texts, which most of the world's writing systems use.

- more than 128,000 characters from about 135 modern and historic scripts
- Technologies such as modern operating systems, XML, Java, and the Microsoft .NET Framework have adopted the Unicode standards.

OFFSET In computing, an offset usually refers to either the start of a file or the start of a memory address. Example: If "A" denotes address 80, then the expression A+20 implies the address 100, where 20 in the expression is the offset

File carving is a technique to recover files and fragments of files from unallocated space of the hard disk in the absence of file metadata

JPEG- lossy compression file type for images, can achieve 90% compression. The first bits of a file represent the file type and JPEG files start with hex value **ff d8 ff**

BMP- device independent bitmap (DIB) file format or a bitmap, is a standard graphics image file format used to store images on Windows operating systems. Bitmap images can include animations. The size and color of these images can vary from 1 bit per pixel (black and white) to 24-bit color (16.7 million colors). **RGBQUAD array**: A color table that comprises the array of elements equal to the colors present in the bitmap; this color table does not support bitmaps with 24 color bits, as each pixel is represented by 24-bit RGB values in the actual bitmap. **BMP** Files start with hex value **42 4d** or **BM** in ASCII

GIF is a file format that contains 8 bits per pixel and displays 256 colors per frame. GIF uses lossless data compression techniques, which maintain the visual quality of the image. The hex value of a GIF image file starts with the values **47 49 46**, which represent the GIF file name.

PNG, short for Portable Network Graphics, is a lossless image format intended to replace the GIF and TIFF formats. Supports 24-bit true color, transparency in both the normal and alpha channels as well as indexed/palette-based images of 24-bit RGB or 32-bit RGBA colors and grayscale images. PNG file hex values begin with **89 50 4e**, which is the hex value for GIF.

PDF device independent and support different systems like MAC, Linux, etc. Support different compression algorithms and several multimedia elements. Allows password protection

Autopsy is a digital forensics platform and graphical interface to The Sleuth Kit® and other digital forensics tools. Law enforcement, military, and corporate examiners use it to investigate what happened on a computer. You can even use it to recover photos from your camera's memory card

The Sleuth Kit® (TSK) is a library and collection of command line tools that allow you to investigate disk images. The core functionality of TSK allows you to analyze volume and file system data. The plug-in framework allows you to incorporate additional chapters to analyze file contents and build automated systems. The library can be incorporated into larger digital forensics tools and the command line tools can be directly used to find evidence. **To perform analysis, create a forensics image .dd or. E01**

- **'fsstat'** displays the details associated with a file system. The output of this command is file system specific.
- **istat** - Display details of a meta-data structure (inode)
- **fls** - List file and directory names in a disk image.
- **img_stat** - Display details of an image file

Chapter 3 Summary

- The disk drive is a hardware device that reads data from a disk and writes onto another computer disk.
- Types of disk drives include: magnetic storage devices, optical storage devices, and flash memory devices
- The HDD is a non-volatile, random access digital data storage device used in any computer system
- SSD is a data storage device that uses solid state memory to store data and provides access to the stored data in the same manner as an HDD drive
- Slack space is the area of a disk cluster between the end of the file and cluster

- A master boot record (MBR) is the first sector ("sector zero") of a data storage device such as a hard disk
- Booting refers to the process of starting or resetting operating systems when the user turns on a computer system. It is of two types: Cold boot (Hard boot) and Warm boot (Soft boot)
- The file system is a set of data types, which is employed for storage, hierarchical categorization, management, navigation, access, and recovering the data
- File carving is a technique to recover files and fragments of files from unallocated space of the hard disk in the absence of file metadata

Chapter 4

Data acquisition is the first pro-active step in the forensic investigation process. The aim of forensic data acquisition is to extract every bit of information present on the victim's hard disk and create a forensic copy to use it as evidence in the court. In some cases, data duplication is preferable instead of data acquisition to collect the data. Investigators can also present the duplicated data in court.

Live Data Acquisition

It is the process of acquiring volatile data from a working computer (either locked or in sleep condition) that is already powered on. Volatile data is fragile and lost when the system loses power or the user switches it off. Such data reside in registries, cache, and RAM. Since RAM and other volatile data are dynamic, a collection of this information should occur in real time.

Static Data Acquisition

It is the process of acquiring the non-volatile or unaltered data remains in the system even after shutdown. Investigators can recover such data from hard drives as well as from slack space, swap files, and unallocated drive space. Other sources of non-volatile data include CD-ROMs, USB thumb drives, smartphones, and PDAs. The static acquisition is usually applicable for the computers the police had seized during the raid and include an encrypted drive.

Volatile Data Collection Methodology

1. Incident Response Preparation

- a. **The following should be ready before an incident occurs:**
 1. A first responder toolkit (responsive disk)
 2. An incident response team (IRT) or designated first responder
 3. Forensic-related policies that allow forensic data collection

2. Incident Documentation

- a. Document all information about incident
- b. Use logbook to record all actions during collection

3. Policy Verification

- a. Read and examine all policies signed by the user of suspect computer
- b. Determine forensic capabilities and limitations of the investigator by determining legal rights of user

4. Volatile Data Collection Strategy

- a. Devise strategy based on type of data, source(s) of data, type of media, etc..

5. Volatile Data Collection Setup

- a. Establish trusted command shell to minimize footprint and any malware triggers
- b. Establish transmission and storage method
- c. Ensure integrity of tool output with MD5 hash for admissibility

6. Volatile Data Collection Process

- a. Record time, date, command history and do so when using tools/commands
- b. Document forensic activities and do not restart or shutdown until complete
- c. Maintain a log of all actions performed, photo the screen, identify OS
- d. Check system for use of encryption, dump RAM to sterile storage
- e. Complete full report of steps taken and evidence gathered

A chain of custody document is a written record consisting of all the processes involved in the seizure, custody, control, transfer, analysis, and disposition of physical or electronic evidence. It also includes the details of people, time and purpose involved in the investigation and evidence maintenance processes.

Media sanitization is the process of permanently deleting or destroying data from storage media.

NIST SP 800-88 Guidelines= Clear, Purge, Destroy

Enable Write Protection on the Evidence Media

If hardware write blocker is used:

- Install a write blocker device
- Boot the system with the examiner's controlled operating system
- Examples of hardware devices: CRU® WiebeTech® USB WriteBlockerTM, Tableau Forensic Bridges, etc.
- If software write blocker is used:
- Boot the system with the examiner's controlled operating system and activate write protection
- Examples of software applications: SAFE Block, MacForensicsLab Write Controller, etc.

Determine Data Acquisition Format

Raw Format creates simple, sequential, flat files of a data set or suspect drive.

Advantages:

- Data transferring is fast
- Can ignore minor data read errors on the source drive
- A Universal acquisition format that most of the forensic tools can read

Disadvantages:

- Takes same storage space as that of original disk or data set
- Some tools like freeware versions may not collect bad sectors on the source drive

Proprietary Format Raw format and advanced forensics format are open source formats, and these are the only proprietary format.

- These formats can change from one vendor to another based on features they offer.
- Saves space on target drive and allows to compression of image files of a suspect drive
- Allows splitting an image into smaller segmented files
- Ensures data integrity by applying data integrity checks on each segment while splitting
- It **can integrate metadata** into image file by adding metadata such as date and time of the acquisition, examiner or investigator name, the hash value of the original medium or disk and case details or comments

Advanced Forensics Format (AFF)

- Open source format w/no size restrictions and Space for metadata

Advanced Forensic Framework 4 (AFF4)

- Supports more file formats than AFF and much larger capacities
- Image signing and cryptography and is transparent to clients

Generic Forensic Zip (gfzip)

- Open format for compressed and signed files that uses SHA-256
- Embeds user metadata with file metadata and signs with x.509

Data Acquisition Methods:

Bit-stream disk-to-image

- ProDiscover, EnCase, FTK, TSK, X-Ways, ILook

Bit-stream disk-to-disk

- EnCase, SafeBack, Norton Ghost

Acquiring Data on Linux: dd Command

The syntax for the dd command is as follows:

dd if <source> of<target> bs<byte size> skip seekconv<conversion>

- source: from where to read the data
- target: where to write the data
- Bs: byte size (*usually some power of 2, not less than 512 bytes [i.e., 512, 1024, 2048, 4096, 8192]*)
- skip: number of blocks to skip at the start of the input
- seek: number of blocks to skip at the start of the output
- conv: conversion options

An investigator may use the following commands for the respective tasks:

Suppose a 2GB hard disk is seized as evidence. Use DD to make a complete physical backup of the hard disk, use

dd if=/dev/ hda of=/dev/case5img1

To copy one hard disk partition to another hard disk, use

dd if=/dev/sda2 of=/dev/sdb2 bs=4096 conv=notrunc,noerror command

Following are the important functions **dcfldd** offers that are **not possible with dd**:

1. Hashing on-the-fly - dcfldd can hash the input data, helping to ensure data integrity
2. Status output - dcfldd can update the user of its progress in terms of time or data left
3. Flexible disk wipes - dcfldd can be used to wipe disks quickly, and with a known pattern if desired
4. Image/wipe Verify - dcfldd can verify that a target drive is a bit-for-bit match
5. Multiple outputs - dcfldd can output to multiple files or disks at the same time
6. Split output - dcfldd can split output to multiple files with more configurability than the split command
7. Piped output and logs - dcfldd can send all its log data and output to commands as well as files natively

Acquiring Data on Linux: dcfldd Command

An advanced dcfldd command look like:

**dcfldd if=/dev/sdb hash=md5,sha256 hashwindow=2G md5log=md5.txt sha256log=sha256.txt **
hashconv=after bs=4k conv=noerror,sync split=2G splitformat=aa of=sdb_image.img

Acquiring Data on Windows: AccessData FTK Imager

CRC-32: Cyclic Redundancy Code algorithm-32 is a hash function based on polynomial division idea. The resulting hash value or checksum which is 32 bits.

MD5: It is an algorithm used to check the data integrity by creating 128-bit message digest from the data input of any length. Every MD5 hash value is unique to that particular data input.

SHA-1: Secure Hash Algorithm-1 is a cryptographic hash function developed by the NSA and it is a US Federal Information Processing Standard issued by NIST. It creates a 160-bit (20-byte) hash value called a message digest. This hash value is a hexadecimal number, 40 digits long.

SHA-256: It is a cryptographic hash algorithm that creates a unique and fixed-size 256-bit (32-byte) hash. Hash is a one-way function which means, decryption is impossible. Therefore, it is apt for anti-tamper, password validation, digital signatures and challenge hash authentication.

Chapter 4 Summary

- Data acquisition is the use of established methods to extract the ESI from the suspect computer or storage media to gain insight into a crime or an incident
- Live data acquisition involves collecting volatile information that resides in registries, cache, and RAM
- When collecting volatile information, the collection should proceed from the most volatile to the least volatile
- Static data acquisition is defined as acquiring data that resides in the disk drive, USB, DVD, etc., which remains unaltered when the system is powered off or shutdown
- Select the data acquisition tool that accomplishes the tasks described as mandatory requirements
- Contingency plans must be made in the case the hardware or software does not work, or in case there is any type of failure during acquisition
- Digital evidence validation involves using a hashing algorithm utility to create a binary or hexadecimal number that represents the uniqueness of a data set such as a disk drive or file